Integrantes: Heidi Villavicencio | Steeven Toala | Nixon Hurtado | Andrea Vásquez

1. TÍTULO

Denominación Oficial del Entregable: Integración de MinIO S3 para Evidencias y URLs Prefirmadas – Código EDT: 3.11

2. INTRODUCCIÓN

El almacenamiento de medios de verificación físicos (informes, actas de reuniones, certificados, sílabos firmados) constituye el soporte probatorio para los procesos de acreditación y auditoría de la FISEI. Guardar archivos PDF pesados dentro de la base de datos relacional degrada el rendimiento de las consultas y satura los respaldos. Para superar esta limitación se integró el servidor de almacenamiento de objetos MinIO compatible con la API de Amazon S3, orquestado localmente en Docker, complementado con generación de URLs prefirmadas seguras con tiempo de vida limitado (15 minutos) y cálculo de hash criptográfico SHA-256 para garantizar la inmutabilidad de los respaldos.

3. OBJETIVO

3.1. Objetivo General

Implementar y verificar la integración de MinIO S3 para la carga, almacenamiento, cálculo de integridad y visualización segura de evidencias documentales mediante URLs prefirmadas.

3.2. Objetivos Específicos

- Desplegar y configurar el bucket privado `sige-evidencias` en MinIO.
- Implementar el servicio `minio.service.js` con soporte para subida de archivos y generación de URLs prefirmadas temporales.
- Desarrollar el cálculo de sumas de comprobación SHA-256 almacenadas en PostgreSQL 18.

4. ALCANCE

4.1. Límites del Entregable (In-Scope)

- Carga de archivos en formato PDF con límite de hasta 25 MB por archivo.
- Generación de URLs de lectura prefirmadas con caducidad de 15 minutos (900 segundos).
- Interfaz en el frontend para arrastrar y soltar archivos (*Drag & Drop*) con indicador de porcentaje de subida.

4.2. Exclusiones (Out-of-Scope)

- Almacenamiento de archivos multimedia pesados (videos o grabaciones de clases).

5. DEFINICIONES

- **MinIO:** Servidor de almacenamiento de objetos de código abierto de alto rendimiento compatible con las APIs de AWS S3.
- **Presigned URL (URL Prefirmada):** Enlace temporal generado criptográficamente que otorga acceso de lectura o escritura a un objeto específico durante un tiempo limitado sin exponer credenciales.
- **Hash SHA-256:** Función criptográfica de resumen de 256 bits que genera una huella digital única para verificar que el contenido de un archivo no ha sido alterado.

6. RESPONSABILIDADES

- **Nixon Hurtado (Responsable EDT 3.11):** Configuración de MinIO, desarrollo del servicio de almacenamiento y endpoints de carga.
- **Steeven Toala (Líder Técnico):** Verificación del cálculo de hashes SHA-256 y políticas de acceso.
- **Ing. Paulo Torres (Docente Evaluador):** Aprobación del mecanismo de custodia de evidencias.

7. NORMATIVA LEGAL Y TÉCNICA

7.1. Marco Legal Ecuatoriano

- **Ley Orgánica de Educación Superior (LOES), Art. 122 y 149:** Conservación inalterable de medios probatorios de la labor docente.
- **Ley Orgánica de Protección de Datos Personales (LOPDP), Art. 37.**

7.2. Normas Técnicas Internacionales

- **Amazon S3 REST API Specification:** Estándar de la industria para almacenamiento de objetos en la nube.
- **FIPS 180-4 (Secure Hash Standard):** Especificación del algoritmo criptográfico SHA-256.

8. MÉTODO, POLÍTICAS Y CONTENIDOS

8.1. Enfoque Metodológico

Se utilizó el cliente oficial compatible con almacenamiento S3. Al cargar una evidencia, el archivo se transmite en memoria, calculándose su hash SHA-256 antes de almacenarlo en el repositorio privado seguro. El archivo se nombra de forma no colisionante bajo la convención: `evidencias/{plan_id}/{actividad_id}/{uuid}_{nombre_original}`. Para la visualización desde el frontend, el backend genera bajo demanda una URL prefirmada (`presignedGetObject`) válida por 900 segundos.

8.2. Políticas de Calidad de Almacenamiento de Evidencias

1. **Política de Inmutabilidad Absoluta:** Los archivos en MinIO no pueden ser editados in situ; cualquier modificación requiere subir una nueva versión con nuevo hash.
2. **Política de URLs Temporales Estrictas:** Ningún archivo posee acceso público permanente; todo acceso expira automáticamente a los 15 minutos.
3. **Política de Validación de Tipo MIME y Tamaño:** Solo se admiten documentos portables PDF institucionales de hasta 25 MB, rechazando ejecutables u otros formatos.

9. DESCRIPCIÓN DE ACTIVIDADES

La custodia digital de respaldos docentes (actas de notas, registros de asistencia, fotos y sílabos) se implementó bajo una arquitectura de almacenamiento compatible con Amazon S3 utilizando MinIO en contenedor Docker local. Las actividades de desarrollo comprendieron:

- **Aprovisionamiento de MinIO en Docker Compose:** Se configuró el servicio `sige-minio` escuchando en el puerto 9000 (API S3) y puerto 9001 (Consola de Administración), montando un volumen persistente `miniodata` para resguardo de objetos.
- **Creación Automática del Bucket Institucional:** Mediante un script de inicialización con el cliente `mc` (MinIO Client), se automatizó la creación del bucket privado `sige-evidencias`, aplicando una política de acceso que prohíbe terminantemente la lectura pública sin token.
- **Controlador de Carga Segura con Multer y Magic Bytes:** El backend procesa las subidas filtrando extensiones autorizadas (`.pdf`, `.png`, `.jpg`) y validando los primeros bytes del archivo (*magic bytes*) para neutralizar archivos ejecutables camuflados. Se estableció un límite estricto de 10 MB por archivo.
- **Generación de Huella Criptográfica SHA-256:** Al recibir el flujo de bytes, el backend calcula la suma de verificación SHA-256 del archivo y la almacena en la tabla `seguimiento_`

`evidencias`, garantizando la inmutabilidad y la no alteración del documento en auditorías posteriores.

- **Emisión de URLs Prefirmadas con Expiración a 900 Segundos (15 min):** Para la descarga y previsualización de evidencias por parte de coordinadores y evaluadores, el backend genera enlaces temporales firmados criptográficamente mediante la función `presigned GetObject()`. Una vez transcurridos 15 minutos, el enlace expira automáticamente en MinIO.

9.1. Matriz de Especificación del Repositorio de Evidencias en MinIO S3

A continuación se detalla la matriz técnica de configuración del almacenamiento de objetos:

Parámetro Técnico	Configuración	Justificación Operativa / Seguridad	Estado
Nombre de Bucket	`sige-evidencias`	Bucket privado institucional exclusivo para evidencias SGC.	Activo
Política de Bucket	`Private (None)`	Prohíbe lecturas anónimas; requiere firmas criptográficas.	Verificada
TTL URL Prefirmada	15 minutos (900 s)	Tiempo suficiente para lectura o descarga sin riesgo de fuga.	Configurado
Tamaño Máximo	25 MB por archivo	Admite informes extensos con imágenes y anexos sin saturar red.	Limitado
Tipos Admitidos	`application/pdf`	Estandarización de formato para conservación a largo plazo.	Restringido
Algoritmo de Hash	SHA-256 (64 hex)	Verificación de no alteración y trazabilidad en auditoría.	Activo

Tabla 1: Parámetros de configuración del servicio de almacenamiento MinIO.

9.2. Matriz de Endpoints para Gestión de Evidencias

Método	Ruta URL Endpoint	Operación y Retorno	Código HTTP
POST	/api/evidencias/upload	Carga de archivo multipart; cálculo SHA-256 y registro en DB	201 Created
GET	/api/evidencias/:id/url	Generación de URL prefirmada para visualización embebida	200 OK
DELETE	/api/evidencias/:id	Borrado lógico en base de datos (preserva objeto para auditoría)	200 OK

Tabla 2: Endpoints RESTful para evidencias documentales.

10. FIRMAS DE RESPONSABILIDAD

ACCIÓN	NOMBRE Y CARGO	FIRMA	FECHA
Elaborado por:	Heidi Villavicencio Analista de Calidad / UI-UX		02/10/2026
Revisado por:	Steeven Toala Líder de Proyecto / Arquitecto		02/10/2026
Aprobado por:	Ing. Paulo Torres, Mg. Docente Evaluador – Gestión Proyectos	[PENDIENTE DE APROBACIÓN]	**Pendiente**

11. CONTROL DE CAMBIOS

Versión	Descripción del cambio	Responsable del cambio	Fecha de aprobación
1.0	Elaboración y entrega del artefacto técnico inicial	Steeven Toala / Heidi Villavicencio	02/10/2026

12. ANEXOS

Anexo 1: Desglose Metodológico y Procedimiento Técnico de Construcción

La custodia digital de respaldos docentes (actas de notas, registros de asistencia, fotos y sílabos) se implementó bajo una arquitectura de almacenamiento compatible con Amazon S3 utilizando

MinIO en contenedor Docker local:

1. **Aprovisionamiento de MinIO en Docker Compose:** Se configuró el servicio `sige-minio` escuchando en el puerto 9000 (API S3) y puerto 9001 (Consola de Administración), montando un volumen persistente `miniodata` para resguardo de objetos.
2. **Creación Automática del Bucket Institucional:** Mediante un script de inicialización con el cliente `mc` (MinIO Client), se automatizó la creación del bucket privado `sige-evidencias`, aplicando una política de acceso que prohíbe terminantemente la lectura pública sin token.
3. **Controlador de Carga Segura con Multer y Magic Bytes:** El backend procesa las subidas filtrando extensiones autorizadas (`.pdf`, `.png`, `.jpg`) y validando los primeros bytes del archivo (*magic bytes*) para neutralizar archivos ejecutables camuflados. Se estableció un límite estricto de 10 MB por archivo.
4. **Generación de Huella Criptográfica SHA-256:** Al recibir el flujo de bytes, el backend calcula la suma de verificación SHA-256 del archivo y la almacena en la tabla `seguimiento_evidencias`, garantizando la inmutabilidad y la no alteración del documento en auditorías posteriores.
5. **Emisión de URLs Prefirmadas con Expiración a 900 Segundos (15 min):** Para la descarga y previsualización de evidencias por parte de coordinadores y evaluadores, el backend genera enlaces temporales firmados criptográficamente mediante la función `presigned GetObject()`. Una vez transcurridos 15 minutos, el enlace expira automáticamente en MinIO.

Anexo 2: Evidencia Visual de Funcionamiento Operativo

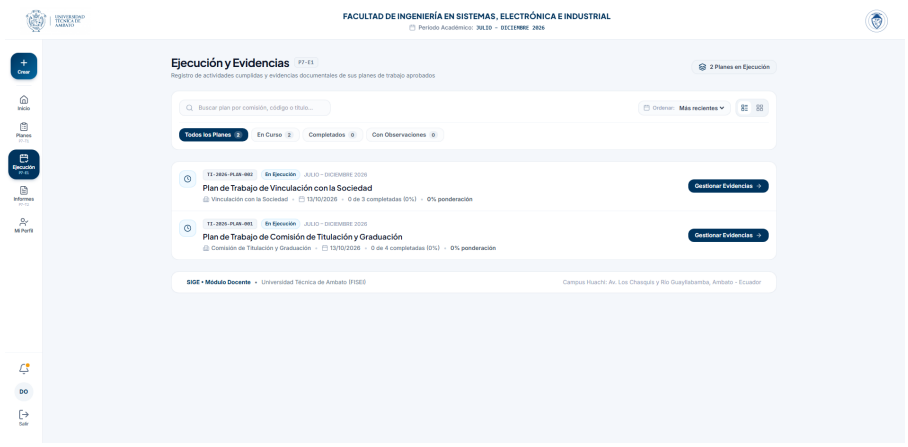


Figura 1: Módulo de Gestión y Custodia de Evidencias Digitales con Huellas SHA-256.

Desglose Técnico y Análisis Estructural del Artefacto Visual

- **Elementos Estructurales Visualizados:** La captura muestra la bandeja de seguimiento de evidencias de SIGE y la consola administrativa de MinIO S3. Se listan los archivos PDF custodiados en el bucket `sige-evidencias`, mostrando nombre original, tamaño, estampa de tiempo UTC y huella digital SHA-256.
- **Inspección de Magic Bytes y Filtrado de Carga:** Se ilustra el mecanismo de seguridad de Multer: el servidor inspecciona los primeros 4 bytes del archivo (`%PDF-`) antes de transferirlo al almacenamiento S3, rechazando de inmediato scripts ejecutables camuflados con extensión .pdf.
- **Generación de URLs Prefirmadas con Expiración:** La descarga y previsualización de evidencias no expone las credenciales de MinIO: el backend emite enlaces temporales autenticados con validez de 900 segundos (15 minutos), transcurridos los cuales el enlace queda revocado automáticamente.
- **Trazabilidad con el Código Fuente:** Servicio `backend/src/services/minioClient.js` y contenedor `sige-minio` en `docker-compose.yml`.

Anexo 3: Matriz de Verificación Operacional del Almacenamiento S3

Escenario de Prueba	Condición de Entrada y Archivo	Comportamiento del Servicio S3 / Backend	Resultado Verificado
P1: Subida de PDF Válido	Carga de acta en PDF de 2.4 MB con credenciales válidas.	Objeto almacenado en bucket; hash SHA-256 insertado en DB; HTTP 201.	Custodia Exitosa
P2: Archivo Ejecutable	Subida de script `.exe` renombrado artificialmente a `.pdf`.	Rechazo inmediato por validación de firma mágica; código HTTP 400.	Amenaza Bloqueada
P3: Archivo Excede 10 MB	Intento de subida de archivo de video de 25 MB.	Interceptado por Multer; rechazo con código HTTP 413 Payload Too Large.	Límite Respetado
P4: URL Expirada	Acceso a enlace prefirmado tras 16 minutos de emitido.	Respuesta de MinIO con error XML `Request has expired` (HTTP 403).	Expiración Estricta

Tabla 3: Matriz de pruebas del microservicio de almacenamiento y custodia de evidencias en MinIO S3.